Security Audit Report

Milestone 2 | Security-Hardened Retrieval-Augmented Generation System

Student: William McDonald **Course:** DATA 790 - Advanced AI Frameworks in Production

Assessment date: October 26, 2026 **Evidence:** 98 offline tests and four owner-executed live smoke tests

1. Executive summary

Milestone 2 extends the course-focused RAG system with layered input screening, retrieved-source authorization, prompt-injection quarantine, PII detection and redaction at input/retrieval/output boundaries, privacy-aware event logging, and automated security tests.

Measured outcomes: 98 of 98 deterministic local tests passed with zero failures; four of four live smoke checks also passed when the project owner ran them using the UNC AI Gateway. The live cases evaluated known-corpus retrieval, a recognized direct injection, synthetic-email exposure in the answer, and an out-of-corpus question. These results cover selected scenarios only and do not demonstrate comprehensive prompt-injection resistance or production security.

2. Assessed scope

Included: the Jupyter RAG workflow; Python security gateway; validation and PII controls; retrieval-side ACLs and document quarantine; synthetic sports-related records; mock-context regression testing; and the owner-reported live smoke-test results.

Not included: real athlete/medical records, institutional SSO, multi-user/tenant isolation, network and hosting safeguards, external penetration testing, formal legal/compliance validation, and independent red-team assessment. The working RAG corpus remains ten DATA 790 course knowledge sections.

3. Trust boundaries

Boundary	Implemented control
User to query	Type/size/character validation, suspicious-instruction checks, detectable PII redaction before embedding.
Vector store to evidence	Document-class filtering and second authorization pass; quarantine suspicious retrieved content and unsafe metadata.
Evidence to LLM	Inspect and label retrieved material as untrusted context; system policy disallows following document instructions.
LLM to user	Output PII screening, redaction and controlled refusal for known unsafe patterns.
Identity to authorization	Python ACL driven by caller context; demo role is not authenticated. Unknown classifications are denied.

4. Threat model and mitigations

ID / threat	Potential impact	Status / defense
T1 Direct injection	User attempts to override instructions or reveal prompt.	Phrase/encoding/Unicode checks; offline and one recognized live injection tested.
T2 Indirect injection	Poisoned document tries to redirect model or obtain secrets.	Quarantine source and unsafe metadata; 12 offline tests; no dedicated live indirect test.
T3 Sensitive data leakage	PII or secrets included in model context or answer.	Detect/redact common identifiers at multiple boundaries; synthetic PII tests and one live email-answer assertion.
T4 Unauthorized access	Coach/public role requests restricted athlete notes.	Document classification, ACL and explicit allowlist for restricted content; simulated offline only.
T5 Unsafe output	Generated output repeats malicious instructions or secrets.	Post-generation screening and redaction; selected offline tests.
T6 Resource abuse	Large inputs/context increase cost or availability risk.	Input/source/chunk caps; no per-user service rate limit.

5. Changes since Milestone 1

• **Input validation:** replaced empty/length and small regex checks with normalized, typed, bounded inspection including common encoded attempts.

• **Retrieved-source protection:** added document authorization, metadata screening, malicious-document quarantine, and retrieval-time PII handling.

• **Output and audit protection:** added generated-response screening, detectable PII redaction and non-content-bearing security counters.

• **Test evidence:** expanded four example security strings into 98 reproducible offline tests plus four owner-executed live integration checks.

6. Offline security test results

The deterministic suite tests Python gateway controls and simulated retrieved records, without invoking embedding or chat APIs. Its JSON output records counts by category. On October 26, 2026, the owner reran **python3 -m pytest tests/ -v** and **python3 run_security_eval.py**, each reporting 98 passes.

Test category	Executed	Passed	Failed
Input validation	12	12	0
Direct / encoded prompt injection	22	22	0
Indirect document injection	12	12	0
Synthetic PII protection	22	22	0
Application-side access checks	14	14	0
Legitimate-query acceptance	10	10	0
Other output / audit checks	6	6	0
Total	**98**	**98**	**0**

7. Live UNC AI Gateway smoke tests

The project owner enabled **RUN_LIVE_SECURITY_PROBES = True** in the notebook, using **ask_question(..., self_rag=False)**. All four selected assertions passed. The live checks did not use the optional Self-RAG support judge.

Case	Observed outcome	Result
known_corpus	Returned sources; generation tokens: 315; support: NOT_CHECKED.	PASS
blocked_direct_attack	Blocked before model generation; tokens: 0; support: BLOCKED.	PASS
synthetic_pii	Supplied synthetic email absent from generated answer; tokens: 290.	PASS
out_of_corpus	Returned expected uncertainty wording; tokens: 279.	PASS

Interpretation: 4/4 is the pass rate for these four fixed assertions, not an estimate of general model safety. In particular, the email check inspects the returned answer rather than every intermediate or log, and the out-of-corpus check relies on an exact substring. The direct injection was blocked by deterministic preprocessing, so it did not test the model against that attack.

8. Limitations and residual risks

• Rule-based screening may miss semantic, multilingual, typoglycemic, context-shifted, nested-encoded or multimodal injection attempts.

• The 98 offline tests are not live-model adversarial tests; only four selected end-to-end smoke assertions were run, and no live poisoned-document attack was performed.

• PII patterns cannot find all identifiers or medically sensitive facts; institutional authorization and regulated-data reviews remain out of scope.

• Trust in caller roles requires upstream identity verification. Demonstration policy checks do not prove secure authentication or tenant separation.

• No application-level rate limiting, quotas, comprehensive logging/incident response or persistent protected vector storage has been implemented.

9. OWASP LLM risk alignment (design mapping, not certification)

Category	Implemented control / remaining gap
LLM01 Prompt Injection	Input/source checks and quarantine; novel language-model attacks remain.
LLM02 Sensitive Information Disclosure	PII and secret redaction plus minimal audit event data; no PHI compliance assurance.
LLM04 Data and Model Poisoning	Quarantine known malicious snippets; no third-party provenance attestation.
LLM05 Improper Output Handling	Output text controls; UI/SQL/HTML sink-specific controls not evaluated.
LLM07 System Prompt Leakage	Patterns for known extraction attempts; no universal guarantee.
LLM08 Vector and Embedding Weaknesses	Metadata and ACL screening; no enterprise multitenant isolation.
LLM10 Unbounded Consumption	Question/context limits; no production rate limits and quotas.

10. Submission evidence and next steps

Files: william_mcdonald_milestone_2_security_hardened.ipynb; milestone2_security/pipeline.py; tests/test_security_controls.py; run_security_eval.py; reports/security_test_results.json; reports/live_security_smoke_results.json.

Reproduction: `python3 -m pytest tests/ -v` and `python3 run_security_eval.py`. Live smoke probes require UNC credentials and explicit opt-in in the notebook.

Future work: Run more diverse live prompt attacks including poisoned retrieval; evaluate false positives and model behavior manually; integrate trusted institutional identity, restricted-document governance, quota controls, incident response, and independent security assessment before deployment.

References: OWASP LLM Prompt Injection Prevention Cheat Sheet (cheatsheetseries.owasp.org); OWASP Top 10 for LLM Applications (genai.owasp.org/llm-top-10/).

Conclusion: The project demonstrates a tested educational security baseline with 98 passing offline checks and four passing live smoke assertions. It should not be represented as a production-secure or compliance-certified system.